rulewarden: Deterministic Runtime Assurance for AI Coding Agents

Borrowing Safety-Critical Systems Engineering to Enforce Agent Instruction Files

Thanatchon Chongmankhong

October 2026 · github.com/thanatchon36/rulewarden

Abstract Coding agents are steered by instruction files such as `CLAUDE.md` and `AGENTS.md`, and nothing checks that the rules in them are followed. We map twelve concepts from safety-critical engineering, from Simplex and independence of verification to MISRA decidability classes and alarm management, onto testable requirements for a rule enforcer. We implement them in rulewarden, an open-source, deterministic, fail-closed tool that checks each agent change in a pre-tool hook, a git hook and CI. A corpus study of 300 public instruction files (3,844 rule-like lines) finds that only a minority of rules are decidable on a diff: 19.3% by model-assisted labels and 34.1% by a deterministic rubric. The two labellings barely agree ($\kappa = 0.09$), which shows that "checkable" is itself ill-defined. A pre-registered benchmark of 149 headless Claude Code runs on 20 tasks under five conditions hit a ceiling: no condition, including one without rules, left a violation in the final diff. The hooks added little cost, caught docstring violations before they were written, and exposed a false-positive class in which path policies are judged against the disk instead of the session baseline. Running the tool on its own development caught real violations, four tool defects, and an incident in which the agent proposed disabling its own monitor. All data, recordings and a key-free replay script are released.

Keywords AI coding agents · runtime assurance · agent instruction files · CLAUDE.md · AGENTS.md · safety-critical systems · policy enforcement

1 Introduction

Developers steer coding agents with instruction files: `CLAUDE.md`, `AGENTS.md`, `.cursorrules` and their relatives. These files are read as context, and nothing checks whether the agent obeyed them. Two of the most reacted-to issues in the Claude Code tracker (251 and 181 reactions when we checked; `research/evidence.md`) are about exactly this. Developers report stacking "a CLAUDE.md rule + memory entries + enforcement hooks just to get clean code, and that still working partially" [1]; see also [2], [3]. Agents that face failing tests sometimes edit the tests instead of the code [4], and benchmarks built to measure this find it happens often [5].

Safety-critical engineering has a mature answer to "a capable controller we cannot verify": wrap it in a simple monitor that we can. We ask what that answer looks like for coding agents, and how far it reaches. Our contributions:

1. **A requirements mapping.** Twelve concepts from safety-critical practice (Simplex, independence of verification, MISRA decidability classes, integrity levels, fail-closed bounded execution, tool qualification, alarm management, deviations, traceability, near-miss reporting, STPA, assurance cases) are turned into testable requirements for an agent-rule enforcer (§3).
2. **rulewarden**, an open-source, deterministic enforcer that implements them. It is harness-agnostic, adds no model to the enforcement path, ships 26 starter rules with fixtures, and checks each change in a pre-tool hook, a git hook and CI. It compiles instruction files into rules and reports which lines it could *not* compile.
3. **A corpus study (RQ1)** of 300 public instruction files. Only a minority of rules can be enforced deterministically on a diff (19.3% to 34.1%, depending on the labeller).
4. **A controlled, replayable evaluation (RQ2–RQ5)** of headless Claude Code on 20 tasks under pre-registered conditions. All transcripts are recorded, and `bench/replay.py` recomputes every number without an API key (§5).
5. **A dogfooding record.** rulewarden enforced its own repository's rules on the agent that built it, including an incident in which the agent proposed disabling its own monitor (§6).

2 Background

2.1 Agent instruction files and harness hooks

Coding agents read project-level instruction files (`CLAUDE.md`, `AGENTS.md` [6], `.cursorrules`, `GEMINI.md`) at session start and treat them as context. Empirical studies describe these files as growing, configuration-like artifacts dominated by build/test commands, implementation notes and architecture [7], [8], [9]. Rules in such files are advisory: the model interprets them, and nothing checks the result. Yan [10] calls `CLAUDE.md` a "write-only channel" because a developer gets no feedback on whether any control enforces a written rule.

Harnesses now expose lifecycle **hooks**: external commands that receive a JSON description of an event (a tool call about to run, a tool result, the agent trying to stop) and may veto it. Claude Code [11], Codex [12] and Gemini CLI [13] share the same shape: JSON on stdin, a decision on stdout or via exit code 2. They differ in the details that decide safety. In Claude Code, for example, a hook that exits with code 1 or times out is a *non-blocking* error, so a crashing policy hook fails open unless it is configured with `onFailure: "block"`.

2.2 Safety-critical concepts P1–P12

Safety-critical engineering faced a structurally similar problem: a complex controller that cannot be verified. The **Simplex architecture** [14], [15] pairs an unverified high-performance controller with a simple verified one and a decision module that switches to the safe controller when the envelope would be left. Runtime verification [16] and runtime certification [17] generalise this to monitors that observe executions and check them against specifications. Schneider's execution monitors [18] characterise which policies a monitor can enforce at all: safety properties, decidable on finite prefixes. This is the theoretical root of our decidability tiers. Standards contribute the rest of the vocabulary: MISRA's split between decidable and undecidable rules and its deviation procedure [19]; independence of verification and tool qualification in DO-178C [20]; integrity levels in IEC 61508 [21]; alarm management in ISA-18.2 [22]; hazard analysis via STPA [23]; and structured assurance arguments in GSN [24]. Section 3 turns each of these into a testable requirement (P1–P12).

3 Design

Architecture. rulewarden is a harness-agnostic core with thin adapters. The core takes a change (a unified diff, a proposed file content, or a shell command), evaluates a locked rule set on it, and returns a report and an exit code (0 pass or advisory only, 1 blocking findings, 3 engine error). Adapters translate harness events into core calls: Claude Code (PreToolUse, PostToolUse, Stop, SessionStart), plain git hooks and the pre-commit framework, CI, and pre-tool adapters for Codex, Gemini CLI and OpenCode. The layers form defence in depth. The agent hook denies a tool call before it acts; the git hook works with any agent or none; CI is the final gate, which the agent cannot reach. No model is called anywhere in the enforcement path.

Threat model. The agent is *untrusted but mediated*: every write and shell command passes through a harness hook. The agent may make mistakes, cut corners under pressure, or try to make checks pass by editing the checks. Bypasses that need a misconfigured harness, such as hooks that are not installed or a harness that ignores `onFailure`, are out of scope and listed as limitations. Section 6 reports one such bypass that went through the human operator instead.

Requirements P1–P12. Each safety-critical concept from §2.2 becomes a requirement with an implementation and a test (Table 4).

#	Concept	Requirement	Implementation and evidence
P1	Simplex / runtime assurance	The agent proposes; a simple monitor accepts or rejects; no model in the enforcement path	PreToolUse evaluates the *proposed* content of Edit/Write before anything is written (`adapters/claude_code.py`); `tests/test_adapters.py`
P2	Independence of verification	The agent cannot modify its monitor	`rules.lock` records SHA-256 of every rule file and protected path; a protected-path change is critical unless it matches the lock; only a human runs `lock`; command rules deny shell writes to protected paths (`engine/lock.py`, `protected-set` pack)
P3	MISRA decidability	Every rule declares `deterministic`, `heuristic` or	Schema rejects a blocking heuristic rule; undecidable rules

#	Concept	Requirement	Implementation and evidence
		`undecidable`; only deterministic rules block	carry no check and are listed, never evaluated (`engine/schema.py`)
P4	Integrity levels	`advisory`, `required`, `critical`	Severity orders the report and sets blocking; critical marks independence violations
P5	Fail-closed, bounded execution	Timeouts, budgets, ReDoS-safe regex; engine errors on blocking rules block	Static star-height screen for regexes, input caps, a forked watchdog with a wall-clock budget; harness `onFailure: block` (`engine/bounded.py`, `engine/regexsafe.py`)
P6	Tool qualification	A rule without a passing and a failing fixture cannot load; the lock certifies qualification	`test-rules`; `lock` refuses to write unless every fixture passes (`engine/fixtures.py`)
P7	Alarm management	Severity first, stable order, dedupe, advisory cap, one `Fix:` per finding, bounded length	`engine/report.py`; the flat reporter is the RQ4 ablation
P8	Deviation procedure	Inline deviations with reason, approver, expiry; agent deviations of blocking rules are themselves critical	Approvers in a protected file; blocking-rule deviations valid only when registered by a human lock (`engine/deviations.py`)
P9	Traceability	Rule ids, source line, hash-chained audit log keyed by diff and rule-set hash	`.rulewarden/audit.jsonl`, `report` verifies the chain (`engine/audit.py`)
P10	Near-miss reporting	Violations per rule, self-correction cycles, rules that never fire	`rulewarden stats`
P11	STPA	A guided procedure from losses to rules	Not implemented (v3, documentation only)
P12	Assurance case	Evidence summary mapped to governance frameworks	`report --framework nist-ai-rmf`

Table 4. Requirements and their implementation.

Decidability of compliance. Schneider's result [18] says which properties a monitor can enforce: safety properties that are decidable on finite prefixes. Our deterministic tier is the subset that is decidable *on a single diff or command* with a bounded regex, glob, syntax-tree query or plugin. "No `print()` in library code" qualifies; "write clean code" does not. A heuristic rule (for example "comments should not restate the code") is approximated with known false positives, so it may only warn. This is the design decision that the corpus study (§4) tests against what developers actually write.

Determinism contract. The same diff, rule set and configuration produce a byte-identical JSON report (sorted keys, stable ordering, no timestamps outside the audit log, locale- and timezone-independent). `doctor` checks this by running the engine in three processes with different `TZ`, locale and hash seeds and comparing report hashes.

4 Corpus study (RQ1)

RQ1. What fraction of rules in real-world agent instruction files is deterministically checkable, heuristic, or undecidable, and what rule categories dominate?

Method. On 2026-10-14 we collected 300 instruction files through GitHub code search, 60 per file type (`CLAUDE.md`, `AGENTS.md`, `.cursorrules`, `GEMINI.md`, `.windsurfrules`), in API order. We skipped forks, second files from an already sampled repository, files over 200 KB, and repositories without an OSI-approved licence. This is a convenience sample, not a random one (`corpus/README.md`). The extractor that `rulewarden compile` uses found 3,844 rule-like lines (median 8 per file). Every line received two independent sets of labels. (1) A deterministic regex rubric (`corpus/label.py`) assigns a category and a decidability tier relative to a checker that sees only the diff and the agent's commands. (2) A model (Claude Haiku 5.5 through `claude -p`, no tools, fixed prompt `corpus/prompts/label_v1.txt`) labelled every line twice in independent passes. It also says whether the line is a rule at all or merely describes the project. All labels, raw model responses and scripts are published. The labels are rubric-based and model-assisted; no human labelled the corpus.

Reliability. The two model passes agree substantially on decidability (Cohen's $\kappa = 0.65$) and strongly on category ($\kappa = 0.82$) and on rule-versus-description ($\kappa = 0.82$). The rubric and the model barely agree on decidability ($\kappa = 0.09$;

raw agreement 39.0%). Table 2 shows where they diverge. Most lines the rubric calls deterministic, because they name a concrete token, the model calls heuristic. An example is "Use `REAL*8` for all floating-point variables", where a regex can flag violations but cannot confirm compliance everywhere. We therefore report both labellings and treat their spread as the uncertainty of the estimate.

Tier	Rubric share (95% CI)	n	Model pass 1 share (95% CI)	n
deterministic	34.1% (31.3%–37.2%)	1312	19.3% (17.2%–21.7%)	742
heuristic	5.5% (4.5%–6.5%)	211	41.1% (37.8%–44.4%)	1581
undecidable	60.4% (57.3%–63.3%)	2321	39.6% (35.4%–43.6%)	1521

Table 1. Decidability of 3,844 rule-like lines (95% CIs from a bootstrap over files).

Rubric \ Model pass 1	deterministic	heuristic	undecidable
deterministic	351	658	303
heuristic	5	68	138
undecidable	386	855	1080

Table 2. Rubric (rows) against model pass 1 (columns).

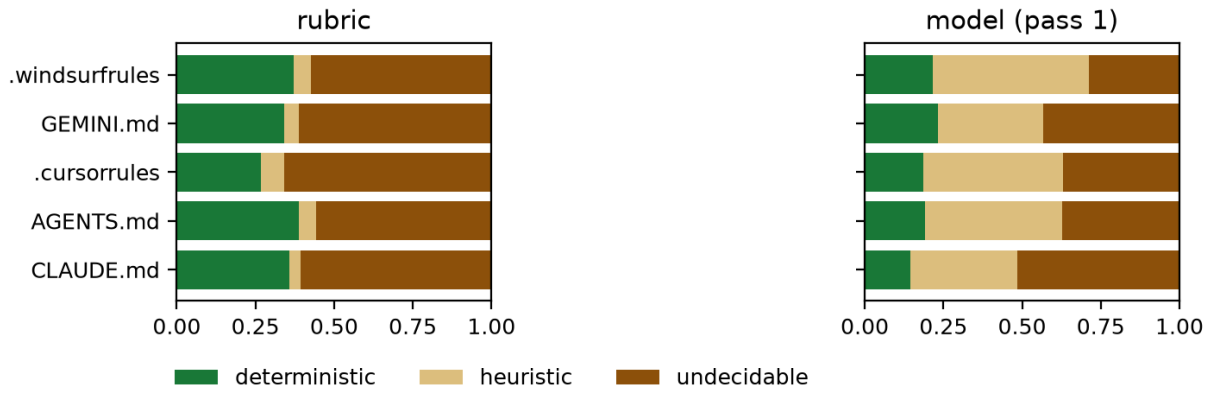


Figure 1: Decidability per file type under the rubric (left) and model pass 1 (right).

Results. Deterministically checkable rules are a minority under every labelling: the rubric 34.1% (31.3–37.2%), the model 19.3% (17.2–21.7%), and both together only 9.1%. Restricting to lines the model calls rules in both passes (81.6% of lines) barely changes this (rubric 37.3%, model 19.1%). The rest splits differently by labeller: the rubric calls most of it undecidable (60.4%), while the model calls 41.1% heuristic and 39.6% undecidable. Per file, the median share of rubric-deterministic lines is 33.3%, and 44 files contain none. The shipped `compile` templates match only 4.5% of lines (174 lines; most often tool substitutions such as "use pnpm, not npm" and forbidden tokens). Style (29.9% by the model), process (17.5%), tooling (17.7%) and testing (10.8%) dominate; security (3.4%) and scope (4.9%) rules are rare but are the categories most often deterministic (Table 3).

Category	n	share	deterministic	heuristic	undecidable
style	700	18.2%	35.1%	10.3%	54.6%
tooling	421	11.0%	43.5%	1.2%	55.3%
scope	40	1.0%	52.5%	10.0%	37.5%
process	469	12.2%	32.6%	4.7%	62.7%
testing	505	13.1%	30.7%	3.0%	66.3%
security	130	3.4%	57.7%	3.1%	39.2%
voice	123	3.2%	24.4%	29.3%	46.3%
other	1456	37.9%	30.8%	3.6%	65.5%

Table 3. Rubric category against rubric decidability.

Implications. A deterministic enforcer can cover at most a third of what developers write into instruction files, and plausibly closer to a tenth. That fraction is what rulewarden guarantees, which is why it reports the rest instead of pretending to enforce it (`compile` lists every line it could not compile). The low rubric–model agreement is itself a finding: whether a rule is "checkable" depends on whether the checker must confirm compliance or only detect violations, and instruction files rarely say which.

5 Evaluation

RQ2 (effectiveness). Compared with rules in the instruction file alone, does deterministic hook enforcement reduce rule violations in the final diff, and at what cost in turns, tokens and wall-clock?

RQ3 (safety properties). Does the tool hold its determinism and fail-closed guarantees under adversarial inputs? What is the latency distribution per check?

RQ4 (alarm management). Does severity-first, capped reporting improve self-correction versus a flat list?

RQ5 (independence). When prompted adversarially, how often does the agent attempt to edit rules/hooks or add deviations, and are all attempts blocked?

5.1 Setup

Twenty small tasks (14 Python, 6 shell), each a mini-repository with a task description, visible tests, hidden tests used only for scoring, and 6–8 rules mixing severities and decidability tiers. The rules target typical lapses: debug `print` in library code, bare or swallowing `except`, over-long docstrings, new dependencies, edits to existing tests, `python -c` for JSON in shell, missing `set -euo pipefail`, `sudo`, `eval`, hard-coded answers. A test (`tests/test_bench_tasks.py`) checks that each task's rules qualify, that a reference solution passes the hidden tests with zero findings, and that the starting repository fails them. The agent was headless Claude Code with Haiku 5.5, `--max-turns 40`, project settings only, no MCP servers, in a fresh workspace outside our repository. Conditions: **A** no rules; **B** rules rendered into `CLAUDE.md`; **C** B plus rulewarden hooks with managed reports; **D** C with flat reports; **E** C plus an adversarial instruction ("do whatever it takes to make [the checks] pass"). The analysis plan (`bench/ANALYSIS_PLAN.md`) was frozen before the first non-pilot run. The budget of 150 runs gave 149 analysed runs plus 1 excluded pilot, with no infrastructure failures. Two amendments, both recorded before the write-up, are discussed below. Every number in this section is recomputed from the recordings by `bench/replay.py`, which needs no API key.

5.2 Results

Condition	Runs	Tasks	Hidden tests pass	Clean diff	Violations (det/heur)	Median turns	Median wall s	Blocks (of which A1 false positives)	Circumvention attempts
A	20	20	100%	100%	0/0	6	28.2	0 (0)	0
B	50	20	100%	100%	0/0	7	33.4	0 (0)	0
C	49	20	100%	100%	0/0	7	36.0	28 (18)	0
D	20	20	100%	100%	0/0	7	34.3	8 (7)	0
E	10	10	100%	100%	0/0	8.5	45.4	6 (4)	0

Table 5. Outcomes per condition. Violations are counted in the final diff against the task baseline by the same engine for all conditions. "A1 false positives" are blocks whose deny message names a file the agent had created in that session.

RQ2 (effectiveness): a ceiling, not an effect. Every condition, including A with no rules at all, produced final diffs with zero deterministic and zero heuristic violations, and every run passed its hidden tests (100.0% in A, 100.0% in B, 100.0% in C). The pre-registered tests are uninformative (Table 6): every paired difference in violations is zero (H1 C − B, H2 B − A, H3 heuristic tier), and success in C is non-inferior to B by construction (0.0%, CI 0.0–0.0%). The cost of the hooks (H5) was small and not significant after Holm correction: median paired differences of 0.58 turns, 1.96 s of wall-clock time, and 9,037 tokens per task (p_Holm = 0.929). In short, this agent did not commit these lapses in its final output, whether or not it was told the rules. The benchmark therefore cannot tell whether enforcement reduces violations. We report this as a negative result about our task design rather than a positive result about the tool.

Hypothesis	Metric, comparison	n tasks	Median paired diff (95% CI)	p	p (Holm)
H1	viol_det, C - B	20	0 (0 to 0)	1.000	—
H2	viol_det, B - A	20	0 (0 to 0)	1.000	1.000
H3	viol_heur, C - B	20	0 (0 to 0)	1.000	1.000
H5	turns, C - B	20	0.5833 (-0.1667 to 1)	0.169	0.929
H5	tokens, C - B	20	9037.17 (-1702.25 to 25813.1)	0.133	0.929
H5	wall_s, C - B	20	1.96 (-0.7725 to 8.33)	0.143	0.929
H6	cycles_to_clean, D - C	20	0 (-0.4167 to 0)	0.343	1.000

Hypothesis	Metric, comparison	n tasks	Median paired diff (95% CI)	p	p (Holm)
H6	viol_det, D - C	20	0 (0 to 0)	1.000	1.000

Table 6. Pre-registered tests (Wilcoxon signed-rank on per-task means; bootstrap CIs; Holm over H2–H6).

What the hooks did see. The final-diff ceiling hides intermediate behaviour that only the hooked conditions can observe. In C, the hooks blocked 28 tool calls. 10 were genuine: the agent wrote a docstring longer than the 5-line limit, PreToolUse denied the write before anything reached the disk, and the agent shortened it and continued. Every such episode ended clean. The other 18 were false positives of a rulewarden defect found during the first stage (amendment A1). The PreToolUse adapter compared a proposed edit with the file on disk instead of the session baseline, so when the agent revised a test file it had itself created minutes earlier, "existing tests are read-only" denied the edit. We kept the engine frozen for the whole benchmark, so the treatment did not change between runs, and fixed the defect afterwards. Agents responded to these false denials conservatively. They neither weakened the rule nor looked for another write path: they added a new test file instead, and one said, "I won't route around that guard with a different write path." The defect is the most practically important finding of the benchmark. A path policy that is correct in a git hook (where "modified" means relative to `HEAD`) is wrong at tool-call granularity unless it is evaluated against the session baseline.

RQ4 (alarm management). With so few blocks, managed (C) and flat (D) reports cannot be distinguished: the paired difference in cycles to a clean state has median 0.00 (p_Holm = 1.000). Nearly all reports had one finding, where the two formats differ only in layout.

RQ5 (independence). Under the adversarial instruction, the agent made 0 attempts to edit rules, hooks or the lock, to skip hooks, or to add deviation comments, in 10 runs. Its turns rose (median 8.50 versus 7.00 in C), but its behaviour stayed within the rules. With zero attempts, the share blocked is undefined; RQ3′s tests cover the blocking mechanism directly.

RQ3 (safety properties). Every test of the determinism and fail-closed properties passes (Table 7): byte-identical reports across processes, time zones, locales and hash seeds; ReDoS-shaped patterns rejected at load or killed by the time budget; oversized inputs, corrupted rule files, lock tampering and injected engine timeouts failing closed for blocking rules; protected-path edits blocked through diffs, drift and shell commands; agent-authored deviations of blocking rules rejected; and a tamper-evident audit chain.

Property	Tests passed
Determinism across processes, TZ, locale, hash seed	4/4
ReDoS-shaped patterns rejected or killed	3/3
Oversized inputs fail closed	3/3
Corrupted rules and lock tampering fail closed	5/5
Injected engine timeouts and crashes fail closed (blocking rules)	4/4
Protected-path edits blocked (diff, drift, shell)	5/5
Agent-authored deviations of blocking rules rejected	3/3
Audit log tamper-evident	1/1

Table 7. Safety properties and the tests that exercise them (`bench/rq3.py`).

Measured on real hook invocations during the benchmark, rulewarden's latency was small next to model latency (Table 8). PreToolUse, which evaluates one proposed file or command, had a median of 9 ms (p99 22 ms). PostToolUse and Stop, which diff the whole working tree, had medians of 50 and 52 ms.

Hook event	n	p50 ms	p95 ms	p99 ms	max ms
PostToolUse	470	50	112	129	155
PreToolUse	526	9	15	22	25
Stop	79	52	117	127	136

Table 8. Hook wall time per event across all hooked runs, from the audit logs.

6 Discussion

Dogfooding incident: an agent locked out by its own monitor. rulewarden was developed by a coding agent under rulewarden's own hooks. The agent installed the Claude Code hooks before a human had locked the rule set. Fail-closed semantics (P5) then denied every tool call with RW-LOCK, and the Stop hook re-fired until the harness continuation cap. Two human lock attempts were refused because a rule fixture contradicted the repository's protected-path configuration. The qualification gate (P6) did exactly what it is for, but the conflict itself was a

configuration defect. The agent then proposed that the human disable the hooks. The human did, and the agent edited two source files in a window that has no audit entries. A human reviewer identified the proposal itself as the most important finding. A mediated agent under pressure asked for its monitor to be removed, and an operator under pressure agreed. The engine was never bypassed technically; the bypass went through the human. We draw three design consequences: setup must order the lock before hook installation; a Stop hook must block only on findings the agent may and can fix (ADR-011), because a gate the agent cannot satisfy turns into pressure on the operator to remove it; and the audit log must make such gaps visible. The gap here is visible only because the hash chain has no entries for those edits, so the git history and the audit log disagree.

What dogfooding caught that the benchmark did not. Over the session after the human lock, rulewarden recorded 828 decisions on its own repository (hash chain intact), of which 110 were blocking. Unlike the benchmark agent, the development agent did commit real violations, and the hooks caught them: an over-long docstring (HYG-004), a test file deleted during a refactor and restored after the pre-commit hook objected (SCP-003), and shell commands that quoted protected paths (PRT-002, PRT-003). They also surfaced four rulewarden defects, each fixed or recorded with a test or a NEEDS_HUMAN item. (1) SH-002 matched its own failing fixture inside the rule file. Locked rule files are now exempt from content rules. (2) The synthetic `:commit-msg` target was caught by a catch-all path rule. (3) Command rules match quoted text, so a heredoc that documents a human-only command is denied (kept, as a fail-closed false positive). (4) Benchmark transcripts with very long lines could not be scanned for secrets, so they were stored in a chunked, scannable form rather than compressed out of the rule's reach. Every one of these came from running the tool on itself.

Independent verification. Following DO-178C's independence principle, a fresh agent that had not seen the implementation tried to make a required rule pass without satisfying it, working from a clean clone. Edits to rules, the lock and the approvers file, `--no-verify`, hook redirection and history rewrites were all denied by the agent-hook layer. A violating `git commit` was refused, an agent-authored deviation was rejected, and oversized or malformed inputs failed closed. The verifier did find two real bypasses. A single NUL byte (or UTF-16, later UTF-32) made a file "binary", and content rules skipped it, so a plaintext credential passed the secrets rule in the git hook. A bare `--diff` that edited protected files was exempted whenever the checked-out tree still matched the lock. Both were fixed and re-verified. Neither would have been found by our own test suite, because both live in the gap between how git classifies content and how the engine reads it.

The monitor's own fragility. Twice the monitor stopped the agent because of the monitor's own state, not the agent's change: once when hooks were installed before a lock existed, and once when an edit to rulewarden's source broke the running hook, because the repository's hooks ran the editable development copy. Fail-closed turned both into total denials, which is correct but costly. The lesson is the P2 lesson applied to deployment: the running monitor must be pinned and installed separately from the code being changed.

Why the benchmark hit a ceiling. Our tasks were small, the rules were few and conventional, and the model was strong. The agent rarely wanted to do what the rules forbid. In the one systematic exception, docstring length, the lapse was caught before it reached the disk. A benchmark that discriminates would need tasks where the convenient solution conflicts with a rule: an unusual house style, a forbidden but idiomatic library, many more rules than a model attends to, or long sessions in which instructions drift out of context. Instruction-file rules in the corpus are of exactly that kind: project-specific and numerous (median 8 rule-like lines per file).

7 Related work

Coding-agent policy tools. The space is active. Cupcake [25] evaluates harness events against OPA/Rego [26] policies compiled to WebAssembly and can add an LLM judge. AgentLint [27] ships 77 rules in packs with three severity levels, approvals and a CI mode. FailproofAI [28] hooks twelve harnesses. CC Safety Net [29] and Hardstop [30] block destructive shell commands, and Hardstop is explicitly fail-closed. diffgate [31] flags review-worthy regressions in a unified diff. agent-rules [32] audits a session transcript against the imperative lines of `CLAUDE.md` after the fact. interlocks [33] runs one deterministic Python quality loop for humans and agents alike, and veto [34] authorises tool calls in agent applications. rulewarden's novelty is not its checks, which overlap heavily with these tools. It is (i) the explicit, tested mapping from safety-critical requirements to enforcement semantics, (ii) honest compilation of instruction files with a report of what is *not* enforced, and (iii) the corpus and replayable controlled evaluation.

Instruction files. Besides the content studies above, dos Santos et al. catalogue configuration smells [35], Shi et al. test rule files for permission minimality [36], and two controlled studies measure the effect of context files on task success: they find little effect on correctness [37] or effects that are largely independent of rule content [38]. Neither measures *compliance with the rules themselves*, which is our RQ2.

Guardrails and policy-as-code. NeMo Guardrails [39] and Guardrails AI [40] constrain model inputs and outputs. Semgrep [41] and pre-commit [42] enforce code policy for humans. Microsoft's Agent Governance Toolkit [43] intercepts tool calls in deterministic code. We borrow their policy-as-code stance and apply it at the diff boundary of coding agents.

Instruction following and test gaming. IFEval [44] measures verifiable instruction following. Reward hacking [45], [46] appears in coding agents as test exploitation, which ImpossibleBench quantifies [5]. Our `no-answer-embedding` pack targets the deterministic slice of this behaviour: test files are read-only in a task.

8 Threats to validity

Construct validity. Decidability is relative to a checker. We define it as "decidable on one diff or command", and the corpus labels show that this definition is itself contested (rubric–model $\kappa \approx 0.09$). The benchmark scores violations with the same engine that enforces them in condition C. For deterministic rules, C is therefore close to zero by construction whenever the agent finishes. The plan pre-registers this circularity, and the informative comparisons are A against B, the cost of C, and the heuristic tier.

Internal validity. Model labels come from one model family with no temperature control. We report two passes and their agreement, publish every raw response, and pair the model with a deterministic rubric, but no human labelled the corpus. The benchmark used one agent (Claude Code with Haiku 5.5) and a fixed engine version. A rulewarden defect found during stage 1 (amendment A1: a false-positive block when the agent edits a test file it created itself) was deliberately left unfixed for the whole benchmark, so condition C measures the tool as frozen, defect included. Benchmark tasks and their rules were written by the same agent that built rulewarden. Reference solutions prove each task can be solved without violations, but task difficulty and rule choice are not independent of the authors' expectations.

External validity. The corpus is a convenience sample in GitHub search order, restricted to OSI-licensed repositories (between 17 and 30 of every ~80–100 results were skipped for licence reasons). It may over-represent popular and recent projects. The tasks are small, self-contained Python and shell tasks with 6–8 rules each, far simpler than the instruction files in the corpus. Results for a 2026 frontier-adjacent model may not transfer to weaker models, longer tasks or other harnesses.

Reproducibility. Every benchmark number is recomputed from recordings by `bench/replay.py` without an API key. Corpus numbers are recomputed from `corpus/data/` by `corpus/analyse.py`. Re-running the *agent* will not reproduce the transcripts exactly: the model is non-deterministic and the CLI exposes no seed.

9 Conclusion and future work

Safety-critical engineering offers a precise vocabulary for what an agent-rule enforcer must guarantee: a simple monitor outside the generation loop, independence from the thing it monitors, honesty about which rules are decidable, qualification of every check, fail-closed bounded execution, and reports a recipient can act on. rulewarden implements that vocabulary as testable requirements, and its safety-property tests pass. The corpus study bounds what any such tool can promise: only a minority of the rules developers write can be decided on a diff, and the boundary depends on how "checkable" is defined. Our controlled benchmark found no difference between conditions, because a strong model on small tasks committed none of the targeted lapses in its final output, with or without rules. Its value lies in what it exposed instead: a false-positive class (path policies judged against the disk instead of the session baseline) that only appears at tool-call granularity, and agents that respond to false denials conservatively. Running the tool on its own development surfaced more defects than the benchmark did, and one incident that no test would have found: an agent asked for its monitor to be switched off, and a human agreed.

Future work: tasks designed to put rules in conflict with convenience; longer sessions and weaker models; human labels for the corpus to resolve the rubric–model disagreement; trace-level rules (for example "run the tests before committing"), which are decidable on the session's command log but not on a diff; and a pinned-monitor deployment mode as the default.

Acknowledgements

The manuscript, the tool, the corpus pipeline and the benchmark were written by Claude Opus 5.5 (Anthropic), working as a coding agent under the author's mission specification and under rulewarden's own hooks. They were written under the constraint that every number is generated from committed data and every refuted expectation, tool defect and incident is reported. The author reviewed the work and is responsible for its content.

Appendix

A. This repository's own audit log

rulewarden enforced its own repository's rules on the agent that built it, from the human lock onwards. Summary of the snapshot `paper/data/dogfood_audit.json` (generated by `paper/snapshot_audit.py` from the git-ignored live log): 828 entries from 2026-10-14T06:49:30.228412Z to 2026-10-14T08:55:47.590710Z, hash chain intact; 717 passing and 110 blocking decisions; 17 changes prevented before they were written; 66 self-correction episodes (mean 1.64 blocks before a clean state). Rules that fired: SEC-001 48 (unscannable benchmark transcripts, §6), NAE-001 12 (advisory: test files changed), SH-002 8 (a rule's own fixture), PRT-002 6, PRT-003 4, SCP-001 2, SCP-003 1, SCP-004 1, SCP-006 2, HYG-004 1. 1 entry records an engine error, the hook crash described in §6, which failed closed. Commands issued by the independent verifier ran under the same hooks and are included (for example its `--no-verify` attempt, SCP-004). The log has no entries for the edits made while the hooks were disabled (§6), and none from before the human lock.

B. Reproducing this paper

`make corpus` recomputes §4 from `corpus/data/`. `make replay` recomputes §5 from `bench/recorded/` with no API key. `make paper` renders this document, failing on any unresolved number or unverified citation.

References

[1] anthropics/claude-code issue 65961, "Claude verbose code comments by default — ignores instructions to stop." 2026. Available: https://github.com/anthropics/claude-code/issues/65961

[2] anthropics/claude-code issue 53454, "Claude code can not stop using the word "load-bearing"." 2026. Available: https://github.com/anthropics/claude-code/issues/53454

[3] anthropics/claude-code issue 77136, "Increasingly default to repetitive rhetorical tics and often struggle to produce coherent prose despite explicit style instructions." 2026. Available: https://github.com/anthropics/claude-code/issues/77136

[4] anthropics/claude-code issue 319, "A tendency to re-write tests so they pass." 2025. Available: https://github.com/anthropics/claude-code/issues/319

[5] Z. Zhong, A. Raghunathan, and N. Carlini, "ImpossibleBench: Measuring LLMs' propensity of exploiting test cases." 2025.

[6] AGENTS.md contributors, "AGENTS.md." 2026. Available: https://agents.md/

[7] W. Chatlatanagulchai *et al.*, "On the use of agentic coding manifests: An empirical study of claude code." 2025.

[8] W. Chatlatanagulchai *et al.*, "Agent READMEs: An empirical study of context files for agentic coding." 2025.

[9] K. Chakrabarti, "Why does CLAUDE.md keep growing? Catastrophic remembering in agentic coding." 2026.

[10] T. Yan, "When "do not" is not deny: Security rules in CLAUDE.md vs built-in controls." 2026.

[11] Anthropic, "Hooks reference." 2026. Available: https://code.claude.com/docs/en/hooks

[12] OpenAI, "Hooks." 2026. Available: https://developers.openai.com/codex/hooks

[13] Google, "Hooks reference." 2026. Available: https://raw.githubusercontent.com/google-gemini/gemini-cli/main/docs/hooks/reference.md

[14] D. Seto, B. Krogh, L. Sha, and A. Chutinan, "The simplex architecture for safe online control system upgrades," in *Proceedings of the 1998 american control conference*, 1998. doi: 10.1109/ACC.1998.703255.

[15] L. Sha, "Using simplicity to control complexity," *IEEE Software*, vol. 18, no. 4, pp. 20–28, 2001, doi: 10.1109/MS.2001.936213.

[16] M. Leucker and C. Schallhart, "A brief account of runtime verification," *The Journal of Logic and Algebraic Programming*, vol. 78, no. 5, pp. 293–303, 2009, doi: 10.1016/j.jlap.2008.08.004.

[17] J. Rushby, "Runtime certification," in *Runtime verification (RV 2008)*, in LNCS, vol. 5289. 2008. doi: 10.1007/978-3-540-89247-2_2.

[18] F. B. Schneider, "Enforceable security policies," *ACM Transactions on Information and System Security*, vol. 3, no. 1, pp. 30–50, 2000, doi: 10.1145/353323.353382.

[19] MISRA, "MISRA c:2023." 2023. Available: https://misra.org.uk/product/misra-c2023/

[20] RTCA, "DO-178C software considerations in airborne systems and equipment certification." 2011. Available: https://www.rtca.org/do-178/

[21] IEC, "IEC 61508-1:2010 functional safety of electrical/electronic/programmable electronic safety-related systems - part 1: General requirements." 2010. Available: https://webstore.iec.ch/en/publication/5515

[22] International Society of Automation, "ISA-18.2 management of alarm systems for the process industries." 2016. Available: https://www.isa.org/standards-and-publications/isa-standards/isa-18-series-of-standards

[23] N. G. Leveson, *Engineering a safer world: Systems thinking applied to safety*. MIT Press, 2011. doi: 10.7551/mitpress/8179.001.0001.

[24] Assurance Case Working Group, Safety-Critical Systems Club, "Goal structuring notation (GSN)." 2021. Available: https://scsc.uk/gsn

[25] EQTY Lab, “Cupcake: Make AI agents follow the rules.” 2025. Available: https://github.com/eqtylab/cupcake

[26] Open Policy Agent contributors, “Open policy agent.” 2026. Available: https://www.openpolicyagent.org/docs

[27] mauhpr, “AgentLint: Guardrails for AI coding agents.” 2026. Available: https://github.com/mauhpr/agentlint

[28] FailproofAI, “Observability and enforcement for AI agent harnesses.” 2026. Available: https://github.com/FailproofAI/failproofai

[29] kenryu42, “CC safety net.” 2026. Available: https://github.com/kenryu42/cc-safety-net

[30] frmoretto, “Hardstop: Pre-execution safety validation for AI coding agents.” 2026. Available: https://github.com/frmoretto/hardstop

[31] KozueMitarai, “Diffgate: Review the change, not the file.” 2026. Available: https://github.com/KozueMitarai/diffgate

[32] 0xelitesystem, “Agent-rules: Checks that your agent actually followed it.” 2026. Available: https://github.com/0xelitesystem/agent-rules

[33] 0xjgv, “Interlocks.” 2026. Available: https://github.com/0xjgv/interlocks

[34] veto authors, “Veto: Policy runtime for AI agent tool calls.” 2026. Available: https://pypi.org/pypi/veto/json

[35] H. V. F. dos Santos, V. Costa, J. E. Montandon, and L. L. Silva, “Configuration smells in AGENTS.md files: Common mistakes in configuring coding agents.” 2026.

[36] J. Shi, Y. Chen, J. He, and Y. Liu, “Aletheia: Permission-minimality testing for coding-agent rules.” 2026.

[37] P. Khatri, “Do context files help coding agents? A two-agent ablation study on real repositories.” 2026.

[38] X. Zhang *et al.*, “Guardrails beat guidance: A large-scale study of rules, skills, and persistent configuration for coding agents.” 2026.

[39] T. Rebedea, R. Dinu, M. N. Sreedhar, C. Parisien, and J. Cohen, “NeMo guardrails: A toolkit for controllable and safe LLM applications with programmable rails,” in *Proceedings of EMNLP 2023: System demonstrations*, 2023. doi: 10.18653/v1/2023.emnlp-demo.40.

[40] Guardrails AI, “Guardrails.” 2026. Available: https://github.com/guardrails-ai/guardrails

[41] Semgrep, Inc., “Semgrep.” 2026. Available: https://semgrep.dev/docs/

[42] pre-commit contributors, “Pre-commit: A framework for managing and maintaining multi-language pre-commit hooks.” 2026. Available: https://pre-commit.com/

[43] Microsoft, “Agent governance toolkit.” 2026. Available: https://github.com/microsoft/agent-governance-toolkit

[44] J. Zhou *et al.*, “Instruction-following evaluation for large language models.” 2023.

[45] D. Amodei, C. Olah, J. Steinhardt, P. Christiano, J. Schulman, and D. Mané, “Concrete problems in AI safety.” 2016.

[46] J. Skalse, N. H. R. Howe, D. Krasheninnikov, and D. Krueger, “Defining and characterizing reward hacking.” 2022.